M365-14 · External Sharing & Guest Access Governance

How somebody outside the organization gets access to something inside it — with a sponsor, a purpose and an end date.

Field	Value
Document ID	M365-14
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	A. Microsoft 365
Operating tier	Tier 3 — Expert Services owns the tenant configuration; Tier 2 executes individual requests.
Review cycle	Annually, and whenever tenant sharing settings change.
Depends on	M365-15 for the sharing rules by classification.

1. Purpose

Most organizations collaborate outside their walls, and external access is legitimate and frequent: consultants, partner organizations, auditors, vendors, visiting specialists. This document does not make it harder. It makes it accountable, which is a different thing.

A familiar case: a staff member invites an external person into the tenant. That person completes multifactor registration and becomes, in every technical sense, a participant in the organization's Microsoft 365 environment. There is no record of who sponsored them, what for, or when it should end. The invitation is probably appropriate; nothing about the process would tell you if it were not.

> **The problem with guests is not the invitation. It is the absence of an ending.**
> A guest account with no expiry persists indefinitely, retaining whatever access it was given, long after the project that justified it. Nobody notices, because nobody is looking for something that was never recorded.
> Every control in this document is aimed at that: making external access end by default, rather than persist by default.

2. The three things every external access must have

A sponsor	A named staff member who is accountable for this person having access. Not a department — a person. The sponsor confirms at review and is told when the access expires.

A purpose	One sentence saying why. It is what makes review possible: at expiry the question is “is this still true?”, which is answerable, rather than “does this person still need access?”, which is not.
An end date	Default 90 days. Renewable on the sponsor’s request. There is no such thing as a permanent guest — a genuinely permanent external relationship is a vendor or contractor account under ACC-11, which has its own governance.

3. Who may create a guest

> **Only IT Account Services. End-user guest invitation is disabled.**
>
> In many tenants this is a change from the default behaviour, and it is the central control in this document. It is also the one that will generate complaints, so the reasoning should be stated plainly rather than defended case by case.
>
> When any staff member can invite an external identity, the organization has no way to know how many exist, who vouched for them, or what they can reach. Disabling it costs a request; leaving it enabled costs the ability to answer a basic question about who is in the tenant.
>
> The trade is deliberately mitigated by §10: a guest request is a same-day action, not a project.

Where a department needs external collaboration regularly — a sales team with partner companies, a fundraising team with donors — the answer is a standing arrangement agreed once with Tier 3, not per-request friction or an exception to §3.

4. Requesting external access

1. The sponsor raises a ticket with: the person’s name and organisation, their email address, the purpose in one sentence, what they need to reach, and the end date.
2. Tier 2 checks the classification of what they will reach (M365-15 §5). CONFIDENTIAL requires the site owner and Tier 3; RESTRICTED is not shared by this mechanism at all.
3. Tier 2 creates the guest, sets the display name to include the organisation so staff can see at a glance who is external (ACC-02 §3), and records the sponsor, purpose and expiry.
4. Access is granted to a group, not to the individual (M365-11 §2), and scoped to exactly what the purpose requires.
5. The guest completes MFA registration before reaching anything. External identities are subject to the same authentication requirements as organization accounts (ACC-03 §5.1).
6. The sponsor is told the expiry date at the point of creation, so it is never a surprise.

5. What may be shared externally, by classification

Level	External sharing	Notes
PUBLIC	Freely.	It is public.
INTERNAL	To a sponsored guest with an expiry.	The ordinary case. Most external collaboration is here.

Level	External sharing	Notes
CONFIDENTIAL	To a sponsored guest, expiry 90 days maximum, approved by the site owner and Tier 3.	Named individuals only. Never a whole site where a single library would do.
RESTRICTED	Not by this mechanism.	Use an agreed secure channel, recorded, with Tier 4 aware. If the answer seems to be “but we need to send it”, that is a Tier 4 conversation about the right mechanism.

6. Anonymous links

“Anyone with the link” sharing creates access that belongs to no one, cannot be attributed, does not expire unless configured to, and travels wherever the link is forwarded.

- Prohibited for CONFIDENTIAL and RESTRICTED, without exception.
- Discouraged for INTERNAL. Named sharing is barely more effort and is auditable.
- Where enabled, links carry a default expiry set at tenant level — 30 days is a reasonable value — so that a link forgotten is a link that stops working.
- Acceptable for genuinely public material, where it is simply a convenient distribution method.

7. Expiry and review

1. At 14 days before expiry, the sponsor is asked whether the purpose still holds. One question, answerable in a word.
2. No response means the access expires. This is the important part — expiry is the default and renewal is the action, not the reverse.
3. Renewal extends by 90 days and records the sponsor’s confirmation.
4. Quarterly, Tier 2 produces the full guest list with sponsors, purposes and expiry dates, and it goes to Tier 4. A guest with no identifiable sponsor is removed rather than investigated.
5. Where a sponsor leaves the organization, their guests are reassigned or expired as part of the leaver procedure (ACC-01 §7.2 step 9).

8. Removing a guest

- At expiry, automatically.
- When the sponsor says the work is done — sponsors should be encouraged to do this and never made to feel it is a bother.
- When the sponsor leaves and nobody takes over.
- At quarterly review where the purpose no longer holds.
- Immediately, on Tier 4 instruction, where there is a security concern. Removal takes away access. Content the guest contributed stays with the organization, which is worth saying to sponsors who hesitate to end access on a collaborative project.

9. Tenant configuration

Tier 3 owns these settings and changes to them go through M365-21. Recorded here so the intent is documented alongside the configuration.

Setting	Intent
Guest invitation	Restricted to IT Account Services (§3).
Default sharing link type	Specific people, not anyone.
Anonymous link expiry	Enabled, 30 days.
Guest MFA	Required (ACC-03).
Sharing on CONFIDENTIAL and RESTRICTED sites	External sharing off at site level; exceptions per §5 rather than by site setting.
Guest inactivity	Reported quarterly; feeds §7.
Allowed and blocked domains	Reviewed annually. A blocked-domain list is worth maintaining where there is a specific reason and worth not maintaining otherwise.

10. Service levels

Request	Commitment (per GOV-06)
Guest access to INTERNAL content, complete request	P3 — same coverage day where possible. Speed here is what makes §3 acceptable.
Guest access to CONFIDENTIAL content	P3 — 3 coverage days, allowing for owner and Tier 3 approval.
Renewal on sponsor confirmation	Same day.
Removal on sponsor request	Same day.
Urgent removal on security grounds	P1 — 30 minutes (GOV-03).
Quarterly guest report	Produced by Tier 2 on schedule.

11. Records

Record	Held in	Retention
Guest register: person, organisation, sponsor, purpose, scope, expiry	IT register	Live, plus 3 years after removal
Requests and approvals	Ticket	3 years
Renewals with sponsor confirmation	Ticket	3 years
Quarterly review outcomes	Tier 4 record	3 years
Removals, with reason	Ticket	3 years

12. Related documents

ID	Title	Relationship
M365-15	Data Classification & Handling	Supplies §5.
M365-11	SharePoint & OneDrive Permission Management	Guests are permissioned through groups like everyone else.
M365-10	SharePoint Site Request, Provisioning & Ownership	Site-level external sharing settings.
M365-21	Tenant Configuration Change Control	Changes to §9.
ACC-10	Guest & Sponsored External Account Standard	The account-side standard. This document is the sharing side; the two are read together.
ACC-11	Vendor, Contractor & Consultant Account Standard	Where a genuinely long-term external relationship belongs.
ACC-01	Account Lifecycle	§7.2 step 9 — sponsor departure.
ACC-03	MFA Enrollment	Guests register MFA like everyone else.
GOV-03	Security Incident Response	Urgent removal.

Appendix A — Request card

	Have you got	If not
1	A named internal sponsor — a person, not a department	No sponsor, no guest. Ask who is accountable for this person being here.
2	A purpose, in one sentence	Ask for it. It is what makes review possible later.
3	An end date	Default to 90 days. There is no permanent guest.
4	The classification of what they will reach	Check M365-15. RESTRICTED is not shared this way at all.
5	Site owner approval, if CONFIDENTIAL	Get it before creating anything.
6	A group to put them in	Never grant to the individual (M365-11 §2).
7	Display name including their organisation	Set it. Staff need to see at a glance who is external.
8	The sponsor told of the expiry date	Tell them now, so it is never a surprise.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.